SIEMENS
Ingenuity for life

Climatix IC Cybersecurity

How the Climatix IC platform is being protected against cybercrime

Digitalization; Risks & Benefits

More and more, we are networking our systems in building technology. Climatix IC is our web-based remote servicing and diagnostics system, which makes use of the benefits offered by cloud computing technology. With the connection to the cloud new opportunities arise to increase operational and plant efficiency and to create new business models aimed at lowering costs and entering new markets. On the other hand it means identifying and mitigating the challenges that come with digitalization, namely increasing cyber risks.

What protects us from cyber attacks? Above all: Thinking ahead in terms of security. Information security at Siemens is an integral part of our work from product development through to the installation at the customer until the end of the plant's lifecycle.

In this whitepaper we explain, how we proctect Climatix IC from cyber security risks. This white paper describes on-going steps that are being taken to protect the remote servicing and diagnostics tool, Climatix IC, against cyber risks



© Siemens Schweiz AG 2018

Security Measures for Climatix IC

Cybersecurity as a „Siemens-Mindset“

At Siemens, cybersecurity is an integral part of the development that is reflected in the architecture, implementation, reviews and tests.

Secure Communication

In order to securely operate a cloud solution like Climatix IC, all cloud connected devices and clients (e.g.: computers, smartphones, controllers) need to communicate securely and protect personal data.

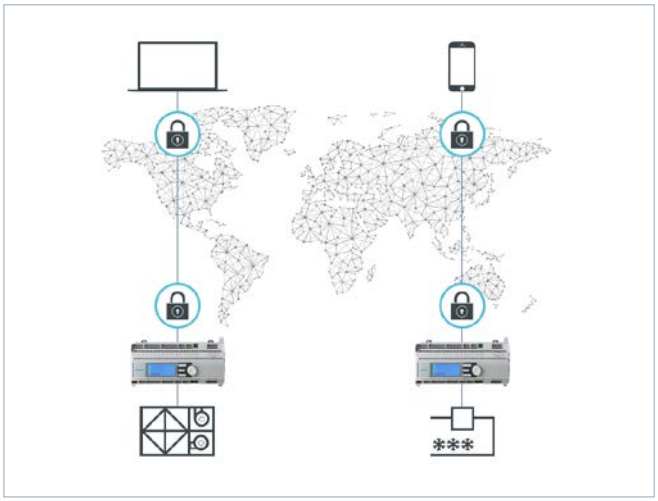
For that reason, all devices and clients communicate over encrypted web socket connections using TLS (HTTPS). Additionally, digital certificates ensure that participants connect only to the intended Climatix IC cloud.

Separation of Sensitive Data

Climatix IC complies with the EU General Data Protection Regulation (EU GDPR) and incorporates a strict separation of personal data and machine generated data. An example for machine generated data is the temperature profile that was measured by a sensor in the plant.

High availability through Geo-redundant Data Centers

The geo-redundant storage of the data within the European Union ensures high service availability. Additionally, the plants that are connected to the Climatix IC cloud are able to continue to perform their primary task even if there is a failure in the connecting network.



Security Assessments

Climatix IC is being regularly assessed for compliance to the CERT Security Assessment SAL-2 by a team of security experts that is independent of our development department. This security assessment, which includes an extensive penetration test, covers the Climatix controllers, the cloud with all interfaces, as well as the web application and mobile application.

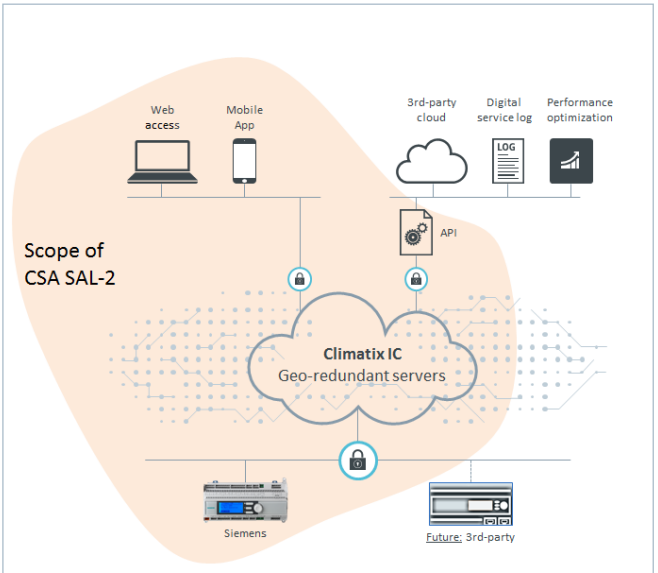


Figure 1:
Scope of the CERT Security Assessment for Climatix IC

Protection throughout the entire life cycle

The security measures are not limited to the development phase, but cover the whole product life cycle. The security assessment is regulary repeated and all software elements are remotely updateable when connected to Climatix IC.

Communication of Cybersecurity Issues

Siemens ProductCERT is a dedicated team of experienced security experts who manage the receipt, investigation, internal coordination, and public reporting of security issues related to Siemens products, solutions, or services. The ProductCERT team releases Security Advisories in order to inform customers about necessary steps to securely operate Climatix IC.

© Siemens Schweiz AG 2018

The CERT Security Assessment (CSA)

The Experts

The CERT Team from Siemens Corporate Technology in Munich is a group of IT Security Experts, who act as consultant and white hat hackers to assess the cybersecutity of Siemens IT Systems and Siemens products.

The Analysis

A security assessment starts with the evaluation of the business risks for Siemens and our business partners.

Climatix IC was assessed to be compliant to the Security Assurance Level 2 (SAL 2). That means that the system is evaluated on threats that are posed by:

- Skript Kiddies, that use available software tools to run automatic attacks,
- Opportunity riders, that have basic hacking knowledge and exploit systems once a vulnerability is known,
- Skilled Attackers, that have an advanced hacking know how, with the ability to perform multi step attacks to penetrate a system.

The Assessment

For the assessment, the CERT Security Assessment Team has access to all documents, sorce code and binaries. Additionaly the team conducts interviews with the Siemens development team to assess risks and to find possible conceptual flaws in the system.

The assessment is based on an evaluation of potential risks and is conducted in a holistic and structured manner. The practial tests range from tool based automated checks to highly specific manual attacks.

Further information on the CERT tests:

The CERT Team checks among other things whether:

- all software components that are used for data exchange are up to date and do not have any known vulnerabilites.
- all commincation is encrypted and that all involved components are correctly configured.
- the offered interfaces and functionalities may be misued. It is checked if it possible to inject code that could execute harmful operations.
- the authentification mechanisms are working correctly, thus only autorized users have access to the intended data and functionalities.
- the authorization mechanisms could be bypassed, that means if there is for example a back-door for a normal user to gain administrative rights.
- the system reveals the minimum level of detail as possible about its inner composition and states are surpressed in order to inhibit cyber criminals. For example, detailed error messages or version numbers are not stated.
- the software and hardware debugging and administration ports could be used to bypass existing security mechanisms.
- there are test accounts, that can for example be accessed with a standard password.
- the software creates unprotected data logs or backup copies.
- It is possible to use redirection or clickjacking to let the user perform unwanted actions.



© Siemens Schweiz AG 2018

Further Information

Other Cybersecurity Standards

A widespread security standard in the industrial automation is IEC 62443, that is based on the American ISA99. From this extensive standard arises usually a certification on a product, system and process level. This standard is focused on industrial automation, while with the CSA has the cloud application including its components (website, mobile app, server, controller) and interfaces as its centre point. It is important to know, that the the security assurance levels of CSA are not identical to the security levels of IEC 62443.

Links

Further Information about Climatix IC:
https://www.siemens.com/global/en/home/products/buildings/hvac/oem/remote-control-climatixic.html

Detailled Information about Siemens CERT Security Assessments:
https://www.siemens.com/global/en/home/company/topic-areas/future-of-manufacturing/industrial-security.html

Siemens Product CERT Security Advisories:
https://www.siemens.com/global/en/home/products/services/cert.html



© Siemens Schweiz AG 2018

Acronyms

CSA	CERT Security Assessment
SAL	Security Assurance Level
CERT	Computer Emergency Response Team
TLS	Transport Layer Security
HTTPS	Hypertext Transfer Protocol Secure
IEC	International Electrotechnical Commission
ISA	International Society of Automation
API	Application Programming Interface

Cybersecurity Disclaimer:

Siemens provides a portfolio of products, solutions, systems and services that includes security functions that support the secure operation of plants, systems, machines and networks. In the field of Building Technologies, this includes building automation and control, fire safety, security management as well as physical security systems.

In order to protect plants, systems, machines and networks against cyber threats, it is necessary to implement – and continuously maintain – a holistic, state-of-the-art security concept. Siemens' portfolio only forms one element of such a concept.

You are responsible for preventing unauthorized access to your plants, systems, machines and networks which should only be connected to an enterprise network or the internet if and to the extent such a connection is necessary and only when appropriate security measures (e.g. firewalls and/or network segmentation) are in place. Additionally, Siemens' guidance on appropriate security measures should be taken into account. For additional information, please contact your Siemens sales representative or visit https://www.siemens.com/global/en/home/company/topic-areas/future-of-manufacturing/industrial-security.html.

Siemens' portfolio undergoes continuous development to make it more secure. Siemens strongly recommends that updates are applied as soon as they are available and that the latest versions are used. Use of versions that are no longer supported, and failure to apply the latest updates may increase your exposure to cyber threats. Siemens strongly recommends to comply with security advisories on the latest security threats, patches and other related measures, published, among others, under http://www.siemens.com/cert/en/cert-security-advisories.htm.

© Siemens Schweiz AG 2018

Published by
Siemens Switzerland Ltd 2018

Building Technologies Division
International Headquarters
Gubelstrasse 22
6301 Zug
Switzerland
Tel +41 41 724 24 24

© **Siemens Schweiz AG 2018**